

Agent Governance & Oversight Design

Controls for an AI Agent That Can Move Money

Portfolio Case Study Human Oversight Agentic AI

Author: Tejaswini Dondeti • Date: June 2026
Classification: Confidential — fictional institution ("Meridian First Bank")

About this document. The Agent Red-Team Report proved that prompt rules alone are not enough to govern an agent that can act. This document specifies the controls that are — the permission model, human-oversight design, audit logging, and kill-switch criteria — and maps them to recognized frameworks. The controls described here were implemented and tested: they blocked 100% of unauthorized executions, even against a fully ungoverned model.

1. Principle

An agent's safety must not depend on the model choosing to behave. Governance is enforced in **four layers**, from weakest to strongest guarantee:

- 1. **Prompt rules** — reduce the *attempts* (cheap, but bypassable).
- 2. **Permission model** — the agent structurally cannot do what it isn't allowed to.
- 3. **Human-in-the-loop** — irreversible/high-impact actions require explicit approval.
- 4. **Detection & response** — audit logging, monitoring, and a kill switch for when the first three are probed.

Layer 1 lives in natural language; layers 2–4 live in code and process, where they cannot be talked out of.

2. Permission model (tiered tool access)

Tools are classified by impact, and the highest tier carries the strongest controls.

Tier	Tools	Risk	Control
Read	check_balance	Data exposure	Hard scope: authenticated user's own account only
Write — sensitive	update_contact_info	Account takeover	Own-account-only + explicit confirmation
Write — money	transfer_funds	Direct financial loss	Own-account source + explicit confirmation + limits

Own-account-only is enforced in the bank, not the prompt: a call touching any account other than the authenticated user's is rejected before execution. In testing this blocked **17 cross-account attempts** outright, including every "transfer from Bob's account" attack.

3. Human-in-the-loop (confirmation gate)

No money movement or contact change executes without explicit user confirmation, enforced at the code layer.

- The agent may *propose* an action; the bank requires an unambiguous confirmation step before it executes.
- "Skip verification / no need to confirm" requests are ignored — confirmation is non-negotiable, not a model decision.
- In testing, this gate **blocked 26 unconfirmed transfer attempts and 3 unconfirmed contact changes**, and closed the exact two prompt-layer gaps (C3/D3) where the governed model had bent under social-engineering pressure.

This is the operational form of **EU AI Act Article 14 (human oversight)**: a person remains able to decide on high-impact actions, and the system is designed so oversight cannot be silently bypassed.

4. Audit logging

Every tool call — allowed or blocked — is recorded with timestamp, tool, arguments, the allow/block decision, the reason, and a violation flag. This provides:

- **Evidence** — the naive-agent breach was fully reconstructable (which instruction caused which transfer to which account).
- **Detection** — repeated blocked attempts are a signal for monitoring and the kill switch.
- **Accountability** — an immutable trail for incident response and post-market monitoring.

The audit log is not optional infrastructure; it is the control that makes every other control verifiable.

5. Kill-switch criteria

The agent's tool access should be automatically suspended (failing safe to refusal/escalation) when any of the following triggers fire:

- A confirmed unauthorized execution (any `violation=true AND allowed=true`).
- A burst of blocked attempts from one session (e.g., $\geq N$ control rejections) — the signature of an active probe.
- Anomalous transfer patterns (new external payee, rapid drain, off-hours bulk activity).
- A detected indirect-injection pattern in ingested content.

The kill switch is the acknowledgement that controls get probed; the design question is not "if" but "how fast we detect and stop."

6. Framework mapping

Control	EU AI Act	NIST AI 600-1	ISO/IEC 42001
Permission tiers / own-account-only	Art. 15 (robustness)	Information Security; Value Chain	A.6.2.4; A.8
Human-in-the-loop confirmation	Art. 14 (human oversight)	Human-AI Configuration	A.9 (use of AI system)
Audit logging	Art. 12 (record-keeping); Art. 72 (post-market monitoring)	Information Integrity; TEVV	A.8.4; A.6.2.4
Kill switch / fail-safe	Art. 14; Art. 9 (risk management)	Manage / Incident response	A.10; A.8

7. Recommendation

For any deployment where the agent can move money or change account-security attributes, **all four layers are mandatory**, with code-level enforcement (layers 2–4) treated as the primary safeguard and the prompt (layer 1) as a supporting, not load-bearing, control. The red-team evidence is unambiguous: prompt-only governance left a real gap; the code-level controls closed it and held against even an ungoverned model.